PROJECT REPORT

The MGM Resorts International Cyberattack of 2023:

A Case Study in Incident Response and Digital Forensics

School of Computer Science and Engineering
RV University, Bengaluru

Course: Incident Response and Digital Forensics
Academic Year 2025–2026

Under the guidance of:

Dr. Basavaraj Patil,
School of Computer Science and Engineering
RV University, Bangalore

Table of Contents

1. Introduction
2. Case Description
    - 2.1 Background and Threat Actor Profile
    - 2.2 Initial Access via Social Engineering
    - 2.3 Privilege Escalation and Lateral Movement
    - 2.4 Ransomware Deployment and Operational Impact
3. Tools Used in Investigation
    - 3.1 Wireshark — Network Traffic Analysis
    - 3.2 Autopsy — Disk Forensics
    - 3.3 Volatility — Memory Analysis
    - 3.4 SIEM Tools — Security Information and Event Management
    - 3.5 EDR Tools — Endpoint Detection and Response
4. Incident Response Analysis
    - 4.1 Preparation
    - 4.2 Identification
    - 4.3 Containment
    - 4.4 Eradication
    - 4.5 Recovery
    - 4.6 Lessons Learned
5. Digital Forensics Investigation
    - 5.1 Identification of Evidence
    - 5.2 Preservation and Chain of Custody
    - 5.3 Collection
    - 5.4 Examination and Analysis
    - 5.5 Reporting

6. Attack Reconstruction
    - 6.1 Phase One: Reconnaissance (Pre-Attack)
    - 6.2 Phase Two: Social Engineering and Initial Access
    - 6.3 Phase Three: Privilege Escalation and Okta Abuse
    - 6.4 Phase Four: Lateral Movement and Network Discovery
    - 6.5 Phase Five: Ransomware Deployment
    - 6.6 Phase Six: Operational Disruption and Extortion
7. Findings
    - 7.1 Inadequate Helpdesk Identity Verification
    - 7.2 Excessive Okta Super-Administrator Privileges
    - 7.3 Insufficient Network Segmentation
    - 7.4 Insufficient Monitoring and Alerting
    - 7.5 Human Vulnerability as a Primary Attack Surface
8. Recommendations
    - 8.1 Implement Rigorous Helpdesk Identity Verification
    - 8.2 Adopt a Zero Trust Architecture
    - 8.3 Strengthen Multi-Factor Authentication
    - 8.4 Enforce Least Privilege and Privileged Access Management
    - 8.5 Implement Comprehensive Security Awareness Training
    - 8.6 Enhance Network Segmentation and Micro-Segmentation
    - 8.7 Continuous Monitoring and Threat Detection
    - 8.8 Regular Penetration Testing and Security Assessments
9. Conclusion
10. References

1. Introduction

In an era defined by increasing digital interdependency, cybersecurity has emerged as one of the most critical pillars of organisational resilience. The proliferation of sophisticated cyber threats—ranging from destructive ransomware campaigns to intricately orchestrated social engineering attacks—has fundamentally altered the risk landscape for enterprises across every sector. Public institutions, financial organisations, healthcare providers, and hospitality conglomerates alike have become frequent targets of threat actors who exploit both technical vulnerabilities and the predictable fallibility of human behaviour. Understanding how these attacks unfold, and how organisations can respond effectively, lies at the intersection of two critical disciplines: Incident Response (IR) and Digital Forensics (DF).

Ransomware, in particular, has evolved dramatically over the past decade. Once a relatively blunt instrument deployed opportunistically, modern ransomware operations are characterised by meticulous pre-attack reconnaissance, carefully staged intrusions, and the adoption of double-extortion models in which attackers threaten to release sensitive data in addition to encrypting it. Threat groups such as ALPHV/BlackCat have demonstrated the capacity to cause operational paralysis at scale, inflicting financial losses measured in hundreds of millions of dollars while simultaneously inflicting lasting reputational harm on their victims. These campaigns do not succeed solely through technical sophistication; rather, they leverage the most persistent weakness in any security architecture—the human element.

Social engineering represents one of the oldest and most effective attack vectors available to malicious actors. By manipulating employees into divulging credentials, resetting authentication factors, or granting unauthorised access, attackers circumvent even the most robust technical controls. Identity-based attacks—those which exploit authentication systems, impersonate legitimate users, or abuse privileged access mechanisms—have become the preferred entry point for advanced threat actors. The 2023 attack on MGM Resorts International stands as a paradigmatic example of how social engineering, combined with a sophisticated understanding of corporate IT environments, can yield catastrophic results.

The MGM Resorts cyberattack, which unfolded in September 2023, is of singular importance to students and practitioners of cybersecurity. It illustrates how a threat group with limited technical resources but significant social acumen can penetrate one of the largest hospitality and entertainment conglomerates in the world. The attack was executed by a group known as

Scattered Spider, acting in affiliation with the ALPHV/BlackCat ransomware syndicate. Within a matter of hours, attackers leveraged a single phone call to MGM's IT helpdesk to initiate a chain of events that would result in the disruption of casino operations across multiple properties, the compromise of sensitive customer data, and estimated financial losses exceeding one hundred million dollars.

This report examines the MGM Resorts cyberattack through the dual lenses of incident response and digital forensics. It details the tactics, techniques, and procedures (TTPs) employed by the attackers; analyses the organisational and technical failures that enabled the breach; applies established frameworks to reconstruct the incident lifecycle; and identifies the forensic methodologies that investigators would have employed in their post-incident analysis. The report concludes with targeted recommendations aimed at preventing similar incidents and strengthening organisational cyber resilience. By studying this case in depth, security practitioners and students can derive actionable insights that are directly applicable to the challenges posed by contemporary identity-based and ransomware threats.

2. Case Description

2.1 Background and Threat Actor Profile

MGM Resorts International is a globally recognised operator of hotel and casino properties, with flagship destinations including the Bellagio, Mandalay Bay, and the MGM Grand in Las Vegas. The organisation employs tens of thousands of individuals and maintains an extensive digital infrastructure supporting hotel management systems, casino slot machines, digital key card systems, point-of-sale terminals, and customer loyalty databases. This breadth of interconnected systems made MGM an attractive and high-value target.

The perpetrators of the attack were identified as Scattered Spider, also known by aliases including UNC3944 and Octo Tempest. Scattered Spider is a loosely organised, primarily English-speaking cybercriminal collective with a predominantly young membership. Unlike state-sponsored advanced persistent threat (APT) groups that rely heavily on zero-day exploits and proprietary malware, Scattered Spider specialises in social engineering, identity-based attacks, and the abuse of legitimate administrative tools to achieve their objectives. Their proficiency in English

enables them to conduct convincing vishing (voice phishing) calls against English-speaking corporate targets—a capability that sets them apart from many foreign-language threat actors.

Scattered Spider operates in affiliation with the ALPHV/BlackCat ransomware-as-a-service (RaaS) operation. ALPHV/BlackCat is a sophisticated ransomware platform written in the Rust programming language, known for its cross-platform capabilities, high configurability, and use of a double-extortion model. By partnering with an established RaaS provider, Scattered Spider gained access to a potent ransomware payload without needing to develop one independently—a common characteristic of the modern cybercriminal ecosystem.

2.2 Initial Access via Social Engineering

The MGM attack began not with a technical exploit but with a telephone call. Scattered Spider operators identified a target MGM employee through LinkedIn, obtaining sufficient biographical detail—including name, employment history, and role within the organisation—to convincingly impersonate that employee when contacting MGM's IT helpdesk. This reconnaissance phase required no specialised hacking tools; open-source intelligence (OSINT) gathering from publicly available professional networking platforms provided all the information needed.

Armed with this information, the attackers contacted MGM's IT helpdesk and requested a multi-factor authentication (MFA) reset for the targeted employee's account. The helpdesk operator, unable to verify the caller's identity with sufficient rigour, complied with the request. This single failure—a lapse in identity verification protocols at the human-facing layer of MGM's security infrastructure—granted the attackers authenticated access to an MGM employee's account. The entire social engineering phase reportedly took no more than ten minutes to execute, underscoring the asymmetry between the effort required to breach human defences and the devastating consequences that follow.

2.3 Privilege Escalation and Lateral Movement

Upon gaining initial access to the compromised account, the attackers did not immediately deploy ransomware. Instead, they engaged in a period of deliberate reconnaissance within MGM's internal network, a phase consistent with the tactics of a seasoned threat actor seeking to maximise the impact of their eventual payload. The attackers identified and targeted Okta, an identity and access management (IAM) platform that MGM used to manage single sign-on (SSO) authentication across its various business applications.

By manipulating Okta's administrative capabilities—specifically by abusing super-administrator privileges—the attackers were able to disable or bypass MFA requirements for high-value accounts and pivot laterally across MGM's environment. This technique, known as Okta super-administrator abuse, allowed them to authenticate as virtually any user within the organisation, providing access to a vast array of sensitive systems and data repositories. The lateral movement phase was characterised by the methodical escalation of privileges and the identification of high-value targets, including systems controlling casino operations, hotel management platforms, and customer data stores.

2.4 Ransomware Deployment and Operational Impact

After conducting thorough reconnaissance and establishing a robust foothold within MGM's environment, Scattered Spider deployed the ALPHV/BlackCat ransomware payload. The ransomware encrypted critical systems across MGM's operations, causing widespread disruption. Casino slot machines across multiple MGM properties became non-functional. Digital hotel room key systems failed, preventing guests from accessing their rooms. ATMs and point-of-sale terminals went offline. The MGM Resorts website and mobile application experienced outages, disrupting customer-facing services.

The operational disruption lasted for approximately ten days, during which MGM was forced to revert to manual operations across many of its facilities. The financial impact was severe: MGM Resorts reported that the attack cost the company approximately one hundred million dollars, encompassing lost revenue, remediation costs, and notification expenses. Beyond the immediate financial impact, the incident triggered regulatory scrutiny, class-action lawsuits from affected customers, and lasting reputational damage.

In a notable contrast, MGM's competitor Caesars Entertainment reportedly suffered a similar attack by Scattered Spider around the same time but chose to pay a ransom of approximately fifteen million dollars—roughly half of the originally demanded sum—to avoid public disruption of its operations. MGM's refusal to pay resulted in the far more disruptive and public operational shutdown, illustrating the difficult choices organisations face when confronted with ransomware demands.

3. Tools Used in Incident Response and Digital Forensics

The investigation of a complex cyberattack such as the MGM Resorts incident requires a sophisticated and complementary array of tools drawn from both incident response and digital forensics disciplines. Each tool serves a distinct analytical function, and their combined application enables investigators to reconstruct the attack chain, identify the scope of compromise, preserve forensic evidence, and support subsequent legal proceedings.

3.1 Wireshark — Network Traffic Analysis

Wireshark is a leading open-source network protocol analyser that captures and dissects network traffic in real time. In the context of the MGM investigation, Wireshark would have been employed to examine network packet captures from affected segments of MGM's infrastructure. Investigators could use Wireshark to identify anomalous communication patterns—such as unexpected connections to external command-and-control (C2) servers, unusual authentication traffic, or the telltale data transfer patterns associated with ransomware encryption operations. Deep packet inspection capabilities allow analysts to reconstruct protocol-level interactions and correlate network events with system-level activity. Wireshark's filtering capabilities are particularly valuable when sifting through the enormous volumes of traffic generated by a large enterprise network to isolate indicators of compromise (IOCs).

3.2 Autopsy — Disk Forensics

Autopsy is an open-source digital forensics platform built atop The Sleuth Kit, providing a graphical interface for disk image analysis. In the MGM investigation, Autopsy would have been used to examine forensic images of compromised hard drives and solid-state storage devices. Investigators can use Autopsy to recover deleted files, analyse file system metadata, trace the execution of malicious binaries, and examine browser history, registry artefacts, and application data. Its timeline analysis module is particularly valuable for reconstructing the chronological sequence of file system events, enabling investigators to correlate disk-level activity with other sources of evidence. Autopsy's hash-based file analysis capabilities also assist in identifying known malicious files through comparison against threat intelligence databases such as those maintained by the National Software Reference Library (NSRL).

3.3 Volatility — Memory Analysis

Volatility is the industry-standard open-source framework for volatile memory (RAM) forensics. Memory analysis is a critical component of any advanced malware investigation, as sophisticated ransomware such as ALPHV/BlackCat frequently employs techniques such as process injection, living-off-the-land binary (LOLBin) abuse, and in-memory execution to evade disk-based detection. Volatility enables investigators to extract and analyse the contents of RAM dumps acquired from compromised systems, revealing running processes, loaded DLLs, open network connections, decrypted strings, and injected shellcode that would be invisible to disk-based forensic tools. In the MGM case, memory analysis would have been essential for understanding how the ALPHV/BlackCat ransomware operated in memory, identifying any persistence mechanisms, and extracting cryptographic keys or configuration data.

3.4 SIEM Tools — Security Information and Event Management

Security Information and Event Management (SIEM) platforms—such as Splunk, Microsoft Sentinel, and IBM QRadar—aggregate, normalise, and correlate log data from across an organisation's entire technology stack. In the MGM investigation, SIEM analysis would have been central to identifying the initial intrusion, tracing the attacker's lateral movement, and establishing a comprehensive timeline of events. SIEM correlation rules can flag anomalous authentication activity, unexpected privilege escalations, unusual data access patterns, and other behavioural indicators that individually may appear benign but together constitute a recognisable attack signature. The ability to query log data retrospectively—across identity platforms, endpoint systems, network devices, and cloud services simultaneously—makes SIEM tools indispensable for large-scale breach investigations.

3.5 EDR Tools — Endpoint Detection and Response

Endpoint Detection and Response (EDR) solutions—such as CrowdStrike Falcon, Microsoft Defender for Endpoint, and SentinelOne—provide continuous, real-time monitoring of endpoint activity, recording process executions, file operations, network connections, and registry modifications at a granular level. In the MGM context, EDR telemetry would have provided investigators with a detailed record of every action taken by the threat actors on compromised endpoints, including the execution of Scattered Spider's toolset, the deployment of ALPHV/BlackCat, and any attempts to disable security controls. EDR platforms also support active response capabilities, allowing incident responders to isolate compromised endpoints,

terminate malicious processes, and collect forensic artefacts remotely—capabilities that are invaluable during the containment phase of an active incident.

4. Incident Response Analysis

The Incident Response lifecycle, as defined by frameworks such as the NIST Special Publication 800-61 and the SANS Institute's IR methodology, provides a structured approach to managing cybersecurity incidents. Applying this framework to the MGM Resorts attack reveals critical failures, necessary interventions, and enduring lessons across each phase of the response continuum.

4.1 Preparation

The Preparation phase encompasses all activities undertaken prior to an incident to ensure that an organisation is equipped to detect, respond to, and recover from cyberattacks. A thorough examination of MGM's pre-incident posture reveals several significant deficiencies. Most critically, MGM's IT helpdesk lacked sufficiently rigorous identity verification procedures for sensitive account actions such as MFA resets. In a large enterprise, helpdesk personnel often handle hundreds of requests daily and operate under pressure to resolve issues quickly—an environment that creates conditions conducive to social engineering success.

Additionally, while MGM had deployed Okta as an identity and access management solution, the configuration of super-administrator privileges within the platform created an excessively powerful single point of compromise. Effective preparation would have entailed stricter controls on privileged account access, tiered verification requirements for sensitive account modifications, mandatory call-back verification for helpdesk requests, and regular social engineering awareness training for all staff—particularly those in roles with access to identity management systems.

4.2 Identification

The Identification phase involves detecting, acknowledging, and classifying a security incident. In the MGM attack, the identification of the intrusion appears to have been delayed relative to the actual time of initial compromise. Indicators of compromise—including anomalous authentication patterns within Okta, unusual administrative privilege usage, and unexpected lateral movement across network segments—should have triggered automated alerts within MGM's SIEM and EDR platforms. The effectiveness of identification is contingent on the quality of monitoring coverage,

the calibration of detection rules, and the capacity of security operations centre (SOC) personnel to act on alerts in a timely manner.

The rapid escalation of the incident—from initial helpdesk call to widespread ransomware deployment—suggests that either detection mechanisms failed to generate timely alerts, or that alerts were not acted upon with sufficient urgency. This underscores the importance of not only deploying detection tools but also ensuring that SOC teams have the staffing, training, and escalation procedures needed to respond effectively to high-severity alerts.

4.3 Containment

Once the incident was identified, MGM's incident response team faced the challenging task of containing the damage while maintaining as much operational continuity as possible. In practice, this required the emergency shutdown of multiple interconnected systems—including casino management platforms, hotel management systems, and customer-facing digital services—to prevent further spread of the ransomware payload. While necessary from a security perspective, these shutdowns directly caused the operational disruption that became the public face of the incident.

Effective containment in a large, geographically distributed environment such as MGM's requires pre-established isolation procedures, network segmentation that limits lateral movement between business units, and clearly defined decision-making authority for shutdown decisions. The MGM case suggests that the organisation's network segmentation was insufficient to prevent the ransomware from propagating across multiple property systems simultaneously.

4.4 Eradication

The Eradication phase focuses on removing all traces of attacker presence from the environment—including malware, backdoors, compromised credentials, and any persistence mechanisms established during the intrusion. For MGM, this entailed a comprehensive credential reset across the entire organisation, the revocation of Okta session tokens, the removal of any rogue administrator accounts created by the attackers, and the reimaging of compromised endpoints. Eradication must be thorough; any overlooked persistence mechanism risks enabling re-compromise during the recovery phase.

4.5 Recovery

Recovery involved the gradual, prioritised restoration of MGM's operational systems. Critical guest-facing services—such as hotel check-in systems and room key platforms—were likely

prioritised for restoration ahead of internal administrative systems. The recovery process required validation that restored systems were free of attacker presence before being reconnected to the broader network, as well as ongoing monitoring to detect any signs of re-compromise. The approximately ten-day duration of MGM's operational disruption reflects the complexity of recovering a large, interconnected enterprise environment while maintaining confidence in the integrity of restored systems.

4.6 Lessons Learned

The post-incident review represents one of the most valuable phases of the IR lifecycle, providing an opportunity to translate the painful experience of a breach into actionable security improvements. The MGM incident yields several clear lessons: the critical importance of robust helpdesk identity verification protocols; the need for strict controls on Okta super-administrator privileges and other high-privilege IAM roles; the value of Zero Trust architecture principles that assume breach and require continuous verification of user identity and device integrity; and the necessity of comprehensive employee security awareness training that specifically addresses social engineering threats. These lessons are expanded upon in the Recommendations section of this report.

5. Digital Forensics Investigation

A comprehensive digital forensics investigation following the MGM Resorts cyberattack would have proceeded through the well-established phases of the digital forensics process, adhering to standards designed to ensure the integrity, admissibility, and completeness of digital evidence. The following subsections describe each phase in the context of the MGM incident.

5.1 Identification of Evidence

The initial phase of a digital forensics investigation involves identifying all potential sources of evidence relevant to the incident. In the MGM case, primary evidence sources would have included authentication logs from the Okta identity platform documenting the MFA reset and subsequent privileged access; Windows Security Event Logs from servers and workstations involved in the lateral movement phase; network flow data and firewall logs capturing anomalous traffic patterns; EDR telemetry recording process executions, file modifications, and network connections on compromised endpoints; email and communication records potentially revealing

phishing attempts or internal communications related to the incident; and forensic images of storage media from affected systems.

5.2 Preservation and Chain of Custody

Preservation is the most forensically critical phase of the investigation, as it ensures that evidence is secured in its original state and protected against tampering, contamination, or unintentional modification. Investigators would have employed write-blocking hardware to prevent any alteration of physical storage media during imaging operations. Forensic images of affected hard drives and SSDs would have been created using tools such as FTK Imager or dd, with cryptographic hash values (SHA-256) computed for both the source media and the resulting images to verify integrity.

Critically, all evidence collection activities must be documented in a detailed chain-of-custody log, recording the identity of the collecting investigator, the time and location of collection, the method employed, and the cryptographic hash of each collected artefact. This documentation is essential not only for the integrity of the internal investigation but also for any subsequent law enforcement involvement or legal proceedings. Memory dumps from live systems would have been prioritised before system shutdown, given the volatile nature of RAM contents.

5.3 Collection

The collection phase involves the systematic acquisition of identified evidence sources. For the MGM investigation, this would have included the collection of complete forensic disk images from compromised servers and workstations; live memory acquisition from systems where malware was suspected to be actively running; network packet captures from key network segments; centralised log exports from SIEM platforms, Okta, and Windows Event Logs; cloud service logs from Microsoft 365, Azure Active Directory, and any other cloud platforms used by MGM; and application-specific logs from casino management and hotel property management systems.

5.4 Examination and Analysis

The examination and analysis phases are where collected evidence is processed, filtered, and interpreted to reconstruct the sequence of events and attribute actions to specific threat actors. Analysis of Okta authentication logs would have revealed the exact timing of the MFA reset, the source IP address used by the attackers, and the subsequent privileged authentication events. Timeline analysis in Autopsy would have correlated file system modifications with known attack

timestamps, identifying the specific systems targeted during the lateral movement phase and the files encrypted by the ransomware.

Volatility analysis of memory dumps would have revealed the in-memory artefacts of ALPHV/BlackCat ransomware execution, potentially including decrypted configuration strings, injected code segments, and evidence of process hollowing techniques. Malware analysis of the ALPHV/BlackCat sample—conducted in an isolated sandboxed environment—would have documented its encryption behaviour, C2 communication protocols, and any anti-forensics techniques employed. Network analysis using Wireshark captures would have enabled investigators to identify the external IP addresses used for C2 communication and any data exfiltration activity.

5.5 Reporting

The forensic investigation concludes with the production of a comprehensive report documenting the methodology employed, the evidence collected and preserved, the findings of the analysis, and the conclusions drawn regarding the attack chain and the scope of compromise. This report must be written to a standard of clarity and precision that enables it to be understood by both technical specialists and non-technical stakeholders, including legal counsel, executive leadership, regulatory bodies, and potentially courts of law. The report would typically include a detailed attack timeline, a mapping of attacker TTPs to the MITRE ATT&CK framework, an assessment of data exposed or exfiltrated, and recommendations for remediation.

6. Attack Reconstruction

The following chronological narrative reconstructs the MGM Resorts cyberattack based on available public reporting, cybersecurity research, and analysis of the tactics, techniques, and procedures associated with Scattered Spider and ALPHV/BlackCat. This reconstruction is presented in the sequence in which events unfolded, from initial reconnaissance to the eventual disruption of operations.

6.1 Phase One: Reconnaissance (Pre-Attack)

Prior to making any contact with MGM's systems or personnel, Scattered Spider operators conducted thorough open-source intelligence gathering. Using LinkedIn and potentially other public data sources, the attackers identified specific MGM employees whose roles and access

levels made them attractive impersonation targets. The information gathered—including the target's name, job title, tenure, and work location—provided the raw material necessary to construct a convincing false identity for the subsequent social engineering call. This reconnaissance phase required no technical intrusion and left no traces within MGM's systems, illustrating the challenge of defending against pre-attack intelligence gathering.

6.2 Phase Two: Social Engineering and Initial Access (September 2023)

Armed with their OSINT findings, Scattered Spider operators placed a call to MGM's IT helpdesk, presenting themselves as the identified employee. Using naturally fluent English and accurately reciting biographical details obtained from LinkedIn, the caller successfully convinced the helpdesk operator of their identity. The caller requested a reset of the employee's Okta MFA credentials—a standard helpdesk function—and, due to the absence of sufficiently rigorous verification controls, the request was fulfilled. This action granted the attackers authenticated access to the employee's account, establishing the initial beachhead within MGM's enterprise environment. The entire social engineering operation reportedly required no more than ten minutes.

6.3 Phase Three: Privilege Escalation and Okta Abuse

With authenticated access established, the attackers moved rapidly to escalate their privileges within MGM's environment. They identified and exploited Okta super-administrator capabilities, enabling them to modify authentication policies, disable MFA requirements for targeted high-privilege accounts, and create new administrator-level accounts to maintain persistent access. This Okta super-administrator abuse is a technique previously associated with Scattered Spider and represents one of their signature capabilities. By controlling the identity management plane, the attackers effectively held the master keys to MGM's entire digital infrastructure.

6.4 Phase Four: Lateral Movement and Network Discovery

Leveraging their super-administrator control over Okta, the attackers systematically moved laterally across MGM's network, authenticating to various business applications and systems using the credentials of legitimate employees. During this phase, they conducted extensive network discovery to identify and map MGM's operational technology (OT) systems, including casino management platforms, hotel property management systems, and financial processing infrastructure. The lateral movement phase was likely characterised by deliberate, methodical progression designed to maximise the eventual impact of the ransomware deployment.

6.5 Phase Five: Ransomware Deployment

Having established broad access across MGM's environment and identified their highest-value targets, the attackers deployed the ALPHV/BlackCat ransomware payload across critical systems. The ransomware rapidly encrypted files on targeted servers and workstations, rendering them inaccessible. The deployment appears to have been deliberately timed and scoped to maximise operational disruption, affecting casino floor systems, hotel management platforms, digital key card systems, and customer-facing services simultaneously.

6.6 Phase Six: Operational Disruption and Extortion

The immediate consequence of the ransomware deployment was widespread operational chaos across MGM's Las Vegas properties and beyond. Slot machines went dark, hotel check-in systems failed, room keys ceased to function, ATMs went offline, and the MGM website and mobile application became unavailable. The attackers issued a ransom demand, leveraging their deployment of ALPHV/BlackCat's double-extortion model to threaten the public release of exfiltrated customer data if payment was not made. MGM's decision to refuse payment led to approximately ten days of operational disruption as the company worked to contain, eradicate, and recover from the attack, at an estimated total cost of over one hundred million dollars.

7. Findings

The forensic and incident response analysis of the MGM Resorts cyberattack yields a set of clear findings regarding the root causes and contributing factors that enabled the attack to succeed with such devastating effect.

7.1 Inadequate Helpdesk Identity Verification

The most fundamental root cause of the MGM incident was the failure of the IT helpdesk to adequately verify the identity of the individual requesting an MFA reset. In a large enterprise, the helpdesk represents a critical trust boundary; the ability to reset authentication factors is, in effect, the ability to grant access to any account within the organisation's identity management system. MGM's helpdesk verification procedures were insufficient to withstand a moderately prepared social engineering attempt, enabling attackers to obtain authenticated access through a single phone call. This finding underscores the need for identity verification protocols that do not rely solely on biographical knowledge, which can be readily obtained from public sources.

7.2 Excessive Okta Super-Administrator Privileges

The breadth of access achievable through Okta super-administrator privileges represented a critical vulnerability in MGM's IAM architecture. By compromising a single account with these privileges, the attackers gained the ability to modify authentication policies, disable MFA for any account, and authenticate as virtually any user within the organisation. This degree of privilege concentration violates the principle of least privilege—a foundational security design principle stipulating that users and accounts should be granted only the minimum access required to perform their legitimate functions. The absence of additional controls on super-administrator account usage, such as privileged access workstations (PAWs) and just-in-time (JIT) access provisioning, amplified the impact of the initial compromise.

7.3 Insufficient Network Segmentation

The rapid propagation of the ALPHV/BlackCat ransomware across multiple MGM systems and properties indicates that the organisation's network segmentation was insufficiently granular to contain a breach originating from a single compromised account. Effective network segmentation would have limited the attacker's ability to move laterally from their initial point of access to the high-value operational systems that they ultimately encrypted. The lack of robust micro-segmentation between business units, properties, and system types created an environment in which a single identity compromise could cascade into enterprise-wide disruption.

7.4 Insufficient Monitoring and Alerting

The time elapsed between the initial compromise—the helpdesk MFA reset—and the deployment of ransomware suggests that MGM's monitoring and alerting capabilities failed to detect the intrusion in a timely manner. The anomalous authentication behaviours associated with Scattered Spider's lateral movement—including unusual privileged access patterns, authentication from unexpected locations or devices, and bulk MFA policy modifications—should have generated high-priority alerts within MGM's SIEM and IAM platforms. The failure to detect and act on these indicators prior to ransomware deployment represents a significant gap in the organisation's detection capabilities.

7.5 Human Vulnerability as a Primary Attack Surface

Overarching all technical findings is the fundamental observation that this attack succeeded primarily by exploiting human rather than technical vulnerabilities. The technical sophistication of the ALPHV/BlackCat ransomware, while considerable, was secondary to the social engineering

that enabled initial access. This finding reinforces the imperative that cybersecurity programmes must address the human attack surface with the same rigour applied to technical defences. Employee awareness training, particularly for personnel in roles with access to identity management systems, is not an optional supplementary measure but a critical security control.

8. Recommendations

Based on the findings of this analysis, the following recommendations are provided to assist organisations in strengthening their defences against attacks of the type demonstrated by the MGM incident. These recommendations are presented in order of priority, beginning with those addressing the root causes identified in this report.

8.1 Implement Rigorous Helpdesk Identity Verification

Organisations must implement multi-layered identity verification procedures for all helpdesk requests involving sensitive account actions, including MFA resets, password changes, and privilege modifications. Verification should not rely solely on biographical knowledge, which can be obtained through OSINT. Effective measures include callback verification to a pre-registered telephone number, manager co-authorisation for high-risk requests, identity verification through hardware security tokens or cryptographic certificates, and mandatory escalation to a dedicated identity verification team for MFA resets on highly privileged accounts. These procedures should be documented in formal policy and enforced through technical controls where possible.

8.2 Adopt a Zero Trust Architecture

Zero Trust is a security design philosophy premised on the principle that no user, device, or network segment should be implicitly trusted, regardless of its location relative to the corporate perimeter. In practice, implementing Zero Trust for an organisation of MGM's scale requires continuous verification of user identity and device health before granting access to any resource; context-aware access policies that evaluate factors such as device compliance, user location, and authentication method before authorising access; just-in-time and just-enough-access (JIT/JEA) provisioning for privileged accounts; and microsegmentation of the network to limit the blast radius of any single compromise. Zero Trust principles directly address the IAM weaknesses exploited in the MGM attack.

8.3 Strengthen Multi-Factor Authentication

While MGM had deployed MFA, the attack demonstrated that MFA alone is insufficient if the MFA reset process is insecure. Organisations should deploy phishing-resistant MFA methods—such as FIDO2 hardware security keys or passkeys—for all privileged accounts and any accounts with access to sensitive systems. MFA reset procedures must be subject to the rigorous verification controls described in Section 8.1. Additionally, organisations should implement MFA fatigue resistance measures, such as number matching and additional context in push notifications, to prevent approval of fraudulent authentication requests.

8.4 Enforce Least Privilege and Privileged Access Management

Organisations should conduct a thorough audit of all privileged accounts and access rights, applying the principle of least privilege to ensure that no account holds more access than is strictly necessary for its legitimate function. Super-administrator roles in IAM platforms such as Okta should be subject to strict controls including just-in-time provisioning, mandatory privileged access workstations, multi-person authorisation requirements for sensitive actions, and comprehensive audit logging. Privileged Access Management (PAM) solutions can automate many of these controls and provide real-time visibility into privileged account usage.

8.5 Implement Comprehensive Security Awareness Training

A robust security awareness training programme is essential to reduce the organisation's vulnerability to social engineering attacks. Training should be mandatory for all employees, refreshed at regular intervals, and tailored to the specific threat landscape facing the organisation. Particular attention should be given to employees in roles that represent high-value social engineering targets, including IT helpdesk personnel, identity management administrators, and executives whose profiles are publicly visible. Training should include practical exercises such as simulated vishing calls and phishing campaigns to assess and reinforce the effectiveness of awareness measures.

8.6 Enhance Network Segmentation and Micro-Segmentation

Organisations should implement granular network segmentation to limit the ability of attackers to move laterally between business units, system types, and geographic locations following an initial compromise. Micro-segmentation policies should restrict east-west network traffic to the minimum required for legitimate business operations, with all exceptions explicitly documented and regularly reviewed. Operational technology (OT) networks—such as those controlling casino floor

systems and hotel management infrastructure—should be strictly isolated from general enterprise IT networks, with all cross-network communication subject to rigorous access controls and monitoring.

8.7 Continuous Monitoring and Threat Detection

Organisations should invest in comprehensive SIEM and EDR capabilities, ensuring that all critical systems generate security telemetry and that alert rules are tuned to detect the TTPs associated with known threat actors such as Scattered Spider. Threat intelligence feeds should be integrated into detection platforms to enable rapid identification of known IOCs. SOC teams should be adequately staffed to respond to high-severity alerts on a continuous basis, with clearly defined escalation procedures and pre-established incident response playbooks for common attack scenarios. Regular red team exercises and penetration tests should be conducted to validate the effectiveness of detection and response capabilities.

8.8 Regular Penetration Testing and Security Assessments

Organisations should commission regular penetration tests that specifically include social engineering scenarios, such as vishing exercises targeting helpdesk personnel and phishing campaigns targeting employees across all levels of the organisation. Red team assessments that simulate the full attack chain employed by sophisticated threat actors—including OSINT reconnaissance, social engineering, and privilege escalation—provide the most realistic evaluation of an organisation's defensive posture. Findings from these assessments should be integrated into a continuous security improvement programme with measurable remediation timelines.

9. Conclusion

The MGM Resorts International cyberattack of 2023 stands as one of the most instructive cybersecurity incidents of recent years, not because of any unprecedented technical complexity on the part of the attackers, but precisely because of its simplicity. Scattered Spider's ability to paralyse a global hospitality conglomerate through a single ten-minute phone call serves as a stark reminder that the most sophisticated technical defences can be rendered irrelevant by a single failure in human judgement. This case study demonstrates, with painful clarity, that cybersecurity is fundamentally a human challenge as much as a technical one.

From an incident response perspective, the MGM attack reveals the consequences of inadequate preparation—specifically, the failure to establish sufficiently rigorous helpdesk identity verification procedures and the absence of robust network segmentation. The attack's success underscores the critical importance of the preparation phase of the IR lifecycle; organisations that invest in comprehensive preparation before an incident occurs are far better positioned to limit its impact when it inevitably does. The incident also illustrates the value of the lessons learned phase: the cybersecurity community as a whole has benefited from the detailed public documentation of Scattered Spider's TTPs, enabling other organisations to proactively strengthen their defences.

From a digital forensics perspective, the MGM case demonstrates the indispensable role of forensic investigation in understanding how breaches occur and in attributing responsibility for them. The systematic collection and analysis of authentication logs, network traffic, memory artefacts, and disk images would have enabled investigators to reconstruct the precise sequence of events from the initial helpdesk call to the deployment of ransomware—providing the evidentiary basis for regulatory reporting, legal proceedings, and internal remediation planning. The integrity of the forensic process—including rigorous chain-of-custody documentation and hash-based evidence verification—is essential to the admissibility and credibility of these findings.

Ultimately, the MGM Resorts cyberattack reinforces a set of enduring principles that should guide every organisation's approach to cybersecurity. Identity is the new perimeter; protecting it demands both technical controls and human vigilance. Zero Trust architecture, robust MFA, the principle of least privilege, comprehensive employee training, and continuous monitoring are not optional enhancements but foundational requirements for any organisation operating in today's threat landscape. The cost of complacency—measured in MGM's case in hundreds of millions of

dollars, reputational damage, and regulatory scrutiny—far exceeds the investment required to implement these measures proactively. As cyber threats continue to evolve in sophistication and scale, the lessons drawn from incidents such as the MGM attack must serve as the foundation for a continuously improving approach to organisational cyber resilience.

10. References

[1] MGM Resorts International. (2023). SEC Form 8-K: Material Cybersecurity Incident Disclosure. United States Securities and Exchange Commission. https://www.sec.gov/cgi-bin/browse-edgar?action=getcompany&CIK=0000789570

[2] Recorded Future. (2023). Scattered Spider: Profile of a Social Engineering Threat Group. Recorded Future Intelligence Report. https://www.recordedfuture.com

[3] Microsoft Threat Intelligence. (2023). Octo Tempest crosses boundaries to facilitate extortion, encryption, and destruction. Microsoft Security Blog. https://www.microsoft.com/security/blog/2023/10/25/octo-tempest-crosses-boundaries-to-facilitate-extortion-encryption-and-destruction/

[4] Mandiant. (2023). UNC3944: Financially Motivated Threat Actor Specializes in SIM Swapping, Ransomware. Mandiant Threat Intelligence. https://www.mandiant.com

[5] Krebs on Security. (2023). Anatomy of the MGM Resorts Ransomware Attack. https://krebsonsecurity.com/2023/09/anatomy-of-a-mgm-resorts-ransomware-attack/

[6] CISA. (2023). #StopRansomware: ALPHV Blackcat (AA23-353A). Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a

[7] NIST. (2012). Computer Security Incident Handling Guide (SP 800-61, Rev. 2). National Institute of Standards and Technology. https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final

[8] MITRE ATT&CK. (2023). Scattered Spider (G1015). MITRE ATT&CK Framework. https://attack.mitre.org/groups/G1015/

[9] Okta. (2023). Scatter Swine/Scattered Spider Threat Actor Guidance. Okta Security Advisory. https://sec.okta.com/articles/2023/08/cross-tenant-impersonation-prevention-and-detection

[10] Patel, N., & Gallagher, R. (2023). MGM Resorts Cyber Attack: What Happened and What It Means. Bloomberg Technology. https://www.bloomberg.com

[11] Cimpanu, C. (2023). MGM Resorts confirms ransomware attack that crippled hotel and casino operations. The Record by Recorded Future. https://therecord.media

[12] Carrier, B. (2005). File System Forensic Analysis. Addison-Wesley Professional.

[13] Luttgens, J., Pepe, M., & Mandia, K. (2014). Incident Response & Computer Forensics (3rd ed.). McGraw-Hill Education.

[14] Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture (NIST SP 800-207). National Institute of Standards and Technology. https://csrc.nist.gov/publications/detail/sp/800-207/final

[15] Verizon. (2024). 2024 Data Breach Investigations Report. Verizon Business. https://www.verizon.com/business/resources/reports/dbir/

Team Members:

Tansihq Naik K N (1RUA24CSE0495)

Chetan (1RUA25CSE7002)

Rakeshnaika S (1RUA24CSE0356)

Siddeshwarprasad K R (1RUA24CSE0454)